The Human Factors of Cybersecurity

Joshua A Rachel

Charleston Southern University

CSCI 405: Principles of Cybersecurity

Patrick Hill

21 October 2025

Abstract

When discussing risk factors in cybersecurity, human error is recognized as the leading cause of data breaches, despite the many technological improvements in defense techniques. This paper examines the human elements of cybersecurity vulnerabilities, including social engineering, cognitive biases, insider threats, and poor security habits. Additionally, the analysis of real-world incidents and industry statistics will highlight the dangers behind exploiting human weaknesses. Best practices including employee training, culture focus, and technical safeguard, provide a comprehensive framework for minimizing the human risk of cybersecurity. The need for a proper security framework is important, as centralized standards that account for human error scenarios improve the chances of developing strong counteractive measures.

Key terms: framework, cybersecurity, human risk

Introduction

The field of cybersecurity focuses heavily on the technological aspects of digital security, such as firewalls, intrusion detection systems (IDS), and encryption standards. For every industry, especially in cybersecurity, these tools are only as useful as their end users. Despite the technological advancements in digital security, human error remains the most vulnerable component of information security (Verizon, 2025). According to Verizon's 2025 Data Breach Investigations Report, their analysts recorded approximately 22,052 security incidents and 12,195 confirmed breaches, with the human element implicated in approximately 60% of those breaches (Verizon, 2025). Unfortunately, Verizon's statistics prove that human error, social engineering incidents, and employee negligence negate even the most effective cyber defense tools.

Due to accidental or intentional cybersecurity incidents, adding human error into the cybersecurity equation complicates matters. Employees are targeted by phishing attacks, fail to practice proper password safety, or neglect to practice good operational security (OpSec). Organizations fall victim to insider threats that exploit company policies and privileges for malicious purposes. This paper will discuss the human elements of cybersecurity by providing statistics, discussing common attack vectors, examining real-world incidents, and propose mitigation strategies to help organizations develop more resilient and security policies.

Human Vulnerabilities in Cybersecurity

According to Verizon's *2025 Data Breach Investigations Report (DBIR)*, the following statistics highlight the unfortunate nature of the human elements of Information Security:

- 60% of data breaches in 2025 involved a human element of some form, which was consistent with last year.
- Malicious third-party involvement in breaches in 2025 doubled from 15% to 30%.
- Median remediation time for leaked information in public repositories (e.g., GitHub) was 94 days.
- Espionage-motivated breaches increased to 17%, with 70% of these incidents utilizing unpatched vulnerabilities.
- 28% of state-sponsored breaches were financially motivated, suggesting dual-purpose cyber campaigns.
- 46% of compromised systems containing corporate credentials were under the Bring Your Own Device (BYOD) policy or were policy violations.
- Malicious emails containing text generated by artificial intelligence have doubled over the past two years.

Social Engineering and Phishing Attacks. There are various social engineering techniques, but all of them share a common attack vector: exploit humans' desire for social action and trust. Phishing remains one of the most successful cyberattack methods. Employees are often deceived by realistic messages or fake login prompts. Even well-trained staff can fall victim to spear-phishing campaigns, which tailor messages to mimic high-ranking staff or

individuals or Scareware, software that uses concerning imagery or messaging to trick the user into interacting with malicious software (Carnegie Mellon University, 2025).

Password Hygiene and Access Control. Poor password practices remain a significant vulnerability to organizational security. According to IBM's 2025 *Cost of a Data Breach Report*, a large percentage of all breaches were linked to compromised or stolen credentials (IBM, 2025). This alarming statistic reveals the startling reality of how little care users have for their password management practices. Attackers exploit credential reuse by utilizing various tactics such as brute force or credential-stuffing attacks. Although multifactor authentication (MFA) reduces the risk of data breaches, it is unable to compensate for poor privacy practices or successful phishing attempts. Unfortunately, incidents such as the 2022-2023 LastPass breach revealed to the public that relying solely on password managers is not a secure practice either despite the convenience.

Insider Threats. Insider threats are defined as "the potential for an insider to use their authorized access or understanding of an organization to harm that organization" (CISA 2025). An insider will use their access to damage an organization's resources, infrastructure, purpose, or personnel. These types of incidents can be classified as one of three types of threats. First, unintentional insider threats occur because of negligence or human error. Second, intentional threats occur due to malicious actions taken against an organization because of personal grievances or personal benefit. Finally, a third category encompasses both Collusive threats and Third-Party threats. Collusive threats are threats where insiders collaborate with outside actors to expose organizational secrets. Third-Party threats occur when contractors or external firms connected to the main organization are compromised (CISA 2025).

Consequences of Human errors

The Costs of Data Breaches. Breaches caused by human error bring more consequences than financial losses. Verizon's 2025 DBIR estimated that the median ransom payment for successful ransomware attacks decreased from $150,000 to $115,000, but the damage to operations and consumer trust and potential litigation dwarfs the ransom itself. Additionally, the number of breaches caused by a third party increased from 15% to 30%, doubling the amount from last year (Verizon 2025). From a consumer perspective, a third-party breach is especially dangerous since consumers trust their personal data to organizations that fail to do their due diligence in maintaining data privacy protection. These third-party breaches can expose names, addresses, social security numbers, or financial information just like the parent company. The 2019 SolarWinds breach demonstrates the dangers that come with indirect compromises, illustrating how a single overlooked vulnerability can escalate into a national security risk (U.S. Government Accountability Office, 2022).

Trust Once Lost, cannot be Recovered. Human error can destroy consumer trust and lead to long term reputational harm. Once this trust is lost, it will never fully recover. According to IBM's 2025 *Cost of a Data Breach Report,* it is estimated that human error and IT failure account for approximately 26% and 23% percent of breaches respectively (IBM, 2025). Additionally, the average cost of a data breach in 2025 was approximately $4.8 million, with 276 days (IBM, 2025) being the average amount of time it takes for a breach to be identified and contained. These prolonged recovery periods increase operational costs and the amount of time it takes to fully recover from the breach. The 2022-2023 data breach of LastPass serves as a grim

reminder of how poor human practices can compromise an entire organization's credibility. A single developer and DevOps engineer's compromised accounts allowed malicious actors to access customer vaults, clear plaintext passwords, cloud storage data, and other sensitive information (SecurityScoreCard 2025). Despite the company's attempts to rebuild consumer confidence, the fallout from the breach was immense, with many users leaving the service and seeking alternative services that have stronger credential protection policies.

Ransomware is a growing threat. Human error also amplifies the effectiveness of ransomware campaigns. Attackers frequently exploit inattentive employees through phishing links or malicious attachments, leading to the installation of encryption malware that halts business operations. Even if the affected organization circumvents the ransom payment, the costs for system restoration, data recovery, and rebuilding consumer trust may be too great for it to handle. The ransomware incident that led to the closure of the 158-year-old firm KNP logistics in July of this year is an example of this issue. The company was unable to recover from the operational disruptions caused by the attack, leading to its closure and the loss of hundreds of jobs. The reason for this breach: the hackers were able to guess a weak password, allowing them to deploy the ransomware (Freed, 2025). These examples show that the human element of cybersecurity is the most important aspect, as it is one of the most consistent issues in Information Security according to the 2025 Verizon report. However, companies may develop proper strategies to minimize the human risks associated with technology.

Mitigation Strategies and Best Practices

Mitigating the risks associated with the human element in cybersecurity requires a holistic approach that accounts for the behavioral and technological risks. The most important practice is implementing a continuous security awareness and training program that constantly adapts to emerging technologies. The training should cover topics such as phishing, social engineering, and privacy practices. Additionally, the training should be practical, scenario-based, and relevant to the industry the organization operates in. There are many options available for strengthening defenses

Multi-factor authentication (MFA) Adoption. First, organizations should invest in multi-factor authentication tools to further protect from credential exposure. While MFA practices cannot account for all types of cybersecurity incidents, they add an extra layer of protection for user accounts. Based on some of the lessons learned from the class, these types of authentication methods can require several key aspects of the user, including:

- Something you know (password).
- Something you are (biometrics).
- Something you have (security token).
- Something you do (behavioral patterns).

Organizations that wish to utilize external authentication tools should conduct audits of any third-party tools and vendors to ensure these companies comply with the organization's security standards. This practice is extremely important, as mentioned in a previous section, there is no organization that is exempt from the risk of a breach.

Insider Threat Mitigation strategies. Next, an organization should invest in educating its employees about the risks posed by insider threats. An effective training program must address unintentional, intentional, and miscellaneous insider threat types and best practices to avoid these issues. Additionally, it should provide real world examples, practical training scenarios, and guidance on recognizing suspicious behavior. Another important strategy is the establishment of clear compliance and reporting policies to provide a sense of responsibility to its employees to be proactive in identifying and reporting any potential threats. The course must be able to adapt to changing technologies, as the rise of artificial intelligence has given cybercriminals new tools to conduct their illicit activities. Administrative staff should regularly review the organization's access control policies and procedures to ensure that the appropriate access is given for its staff.

Risk Management Practices. A final strategy is to conduct regular risk assessments to determine the organization’s weaknesses and develop a disaster response plan. Organizations should partner with trusted third-party cybersecurity firms such as the National Institute of Standards and Technology (NIST) to conduct regular security tests to receive an unbiased review of their systems and policies. Proactive risk management reduces the likelihood of breaches and enables organizations to respond quickly and effectively in the event a cybersecurity incident occurs.

Education and Training. Conducting regular and structured security training programs for staff provides an opportunity to build a security-focused mindset in the organization. The organization can partner with federal organizations such as CISA and SANS to obtain affordable

or free corporate security training programs. For example, SANS offers multiple services such as risk management, compliance training, and security awareness training for an organization. Additionally, administrative staff should examine and outline the organization's security policies and make any adjustments to remain compliant with government security standards. This step is the most difficult to implement but addresses one of the core weaknesses in organizational security.

Conclusion

The human element is one of the most critical aspects of cybersecurity, often undermining an organization's security strategies regardless of how robust they are. Data cited from IBM and Verizon's reports demonstrate that most data breaches involved human error of some kind, involving social engineering, phishing scams, and poor digital security practices. Insider threats present both intentional and unintentional risks that compromise and organization's data, infrastructure, and operations (CISA 2025). The breaches of both SolarWinds and LastPass illustrate the severe financial, operational, and reputational consequences of human-related failures.

Mitigating these risks requires a comprehensive approach that combines technology, training, and risk management. Organizations must implement security tools such as multifactor authentication that adjust based on the staff member's access requirements. Regular training exercises, risk assessments, and fostering a cybersecurity-minded culture ensure that employees understand their roles in safeguarding sensitive information. Organizations must be proactive in addressing the risks associated with the human element of cybersecurity to protect against threats, maintain stakeholder trust, and respond to and recover from incidents competently.

References

Carnegie Mellon University. (2023). *Social Engineering - Information Security Office - Computing Services - Carnegie Mellon University*. Www.cmu.edu; Carnegie Mellon University. https://www.cmu.edu/iso/aware/dont-take-the-bait/social-engineering.html

CISA. (2020, November). *Insider Threat Mitigation Guide | CISA*. Cybersecurity and Infrastructure Security Agency CISA. https://www.cisa.gov/resources-tools/resources/insider-threat-mitigation-guide

CISA. (2025). *Defining Insider Threats*. Cybersecurity and Infrastructure Security Agency CISA; CISA. https://www.cisa.gov/topics/physical-security/insider-threat-mitigation/defining-insider-threats

Freed, A. M. (2025, July 21). *Ransomware Shuts Down 158-Year-Old UK Logistics Firm*. Halcyon.ai; Halcyon Tech, Inc. https://www.halcyon.ai/blog/ransomware-shuts-down-158-year-old-uk-logistics-firm

GAO. (2022, January 13). *Cybersecurity: Federal Response to SolarWinds and Microsoft Exchange Incidents*. Www.gao.gov. https://www.gao.gov/products/gao-22-104746

IBM. (2025). *Cost of a data breach report 2025*. IBM. https://www.ibm.com/reports/data-breach

National Institute of Standards and Technology. (2017). *Framework for improving critical infrastructure cybersecurity* (Version 1.1). https://www.nist.gov

SANS Institute. (2021). *Security awareness training effectiveness: A survey of best practices.* https://www.sans.org

Security Scorecard. (2025). *What Did the LastPass Breach Reveal About Password Manager Security?* (2025). SecurityScorecard. https://securityscorecard.com/blog/what-did-the-lastpass-breach-reveal-about-password-manager-security/

Verizon. (2025). *2025 data breach investigations report: Executive summary.* https://www.verizon.com/business/resources/reports/2025-dbir-executive-summary.pdf